

Web Application Firewalls (WAFs)

Detection and Bypass

CompTIA PenTest+ (PT0-003)

Domain: 4.0: Attacks and Exploits

Objective: 4.5: Given a scenario, perform web application attacks using the appropriate tools.

Video Overview

This video will delve into the essential skills of detecting and bypassing Web Application Firewalls (WAFs), a core component of web application security. Understanding WAFs is vital for penetration testers, as it enables you to refine your attack strategies and effectively assess the security posture of web applications in real-world scenarios. The techniques discussed, such as utilizing specialized tools and encoding payloads, are directly applicable to hands-on security assessments and can significantly enhance your ability to identify vulnerabilities in protected environments.

Key Topics Covered

- **Web Application Firewall (WAF) Definition:** Understanding WAFs as defense mechanisms for web-specific traffic (HTTP/HTTPS).
- **Importance of WAF Detection:** How identifying WAFs influences penetration testing strategies.
- **WAF Detection Tools:**
 - wafw00f: Identifying WAF presence and type.
 - Nmap: Utilizing scripts like `http-waf-detect.nse` for WAF detection.
- **Manual WAF Indicators:** Examining HTTP headers, cookies, and web application traffic for clues.
- **WAF Bypass Techniques:** Changing attack plans to avoid WAF detection.
- **Encoding and Encryption for Evasion:** Transforming malicious payloads to bypass WAF rules.

- **Common Encoding Techniques:** URL encoding and Base 64 for WAF avoidance.
- **Fuzzing Techniques:** Using SQL injection and cross-site scripting attempts to test WAFs.

Student Notes Section